SOC Alpha 2

Analyst : Benjamin Liu

Date : 3/30/2026

1.Excutive Summary

On April 14, 2021, suspicious activity was detected on a monitored Windows endpoint. The investigation confirmed a multi-stage attack beginning with a brute-force login attempt from IP address **192.168.1.20**. A total of 1,804 failed logon attempts were recorded (all network logons – Logon Type 3, Event ID 4625). A successful logon occurred at **10:56:30** on April 14, 2021 (Event ID 4624).

Following initial access, the attacker bypassed Windows Defender by executing a targeted PowerShell command to add an exclusion path. A malicious executable named **chroma.exe** was introduced. The threat actor then performed a DNS query to the WannaCry ransomware killswitch domain **ayylmaojhsstadsfasdfasdfasdfasdf**. Finally, credential dumping was executed using **mimikatz.exe** located at C:\Users\nightmare\Desktop\mimi\x64\mimikatz.exe (associated Process ID 2724 and Thread ID 4260).

This incident represents a classic ransomware-style attack chain involving initial access, defense evasion, and credential access. No data exfiltration or file encryption was observed in the available logs; however, the presence of Mimikatz and the WannaCry killswitch domain indicates the attacker was preparing for lateral movement or ransomware deployment. Immediate containment and remediation are required to prevent further compromise.

2.Mitre Att&ck Mapping

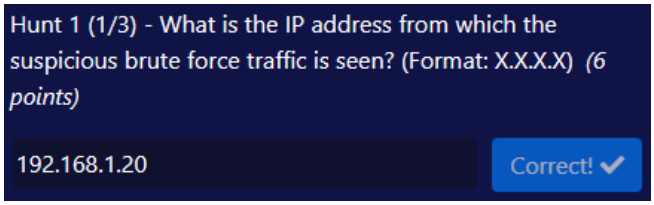
Tactic	Tech ID	Tech Name	Observed Evidence
Initial Access	T1110	Brute Force	1,804 failed logons (Event ID 4625, Logon Type 3) from 192.168.1.20
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools	PowerShell command adding Defender exclusion via Add-MpPreference
Execution	T1059.001	Command and Scripting Interpreter: PowerShell	Full command: `powershell.exe -inputformat none -outputformat none -NonInteractive -command Add-MpPreference -ExclusionPath`
Execution	T1204 / T1036	User Execution / Masquerading	Execution of malicious file chroma.exe
Credential Access	T1003.001	OS Credential Dumping: LSASS Memory	Execution of mimikatz.exe at C:\Users\nightmare\Desktop\mimi\x64\mimikatz.exe (PID 2724, TID 4260)
Discovery / Impact	T1497.001 (related)	Virtualization/Sandbox Evasion	DNS query to WannaCry killswitch domain ayylmaojhsstadsfasdfasdfasdfasdf

3.Recommand Remediation

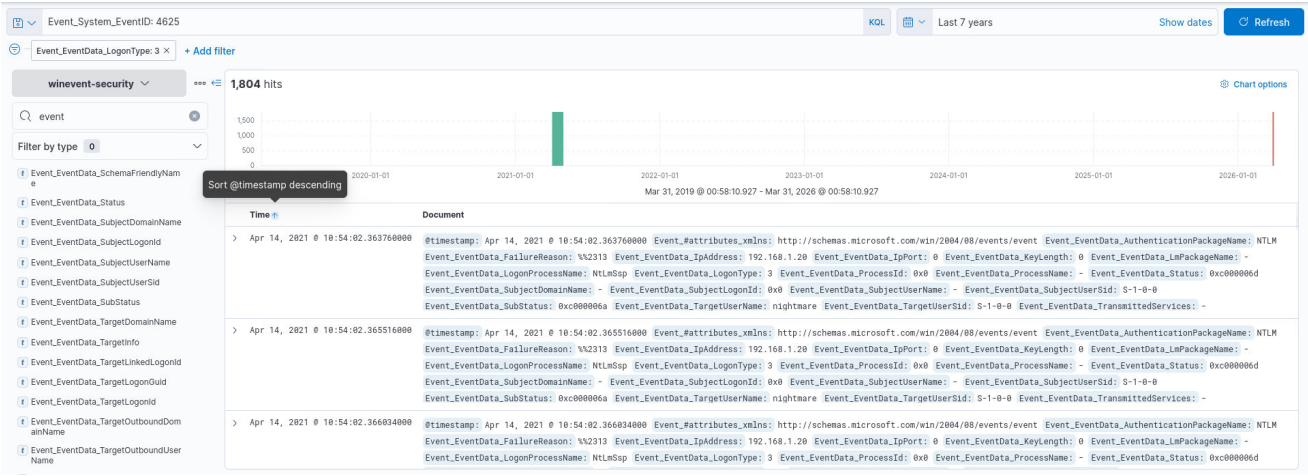
- **Immediate Actions (0–24 hours)**
  - Isolate the affected endpoint and any systems it communicated with.
  - Reset all credentials on the compromised account and any privileged accounts.
  - Block IP 192.168.1.20 at the network level (if still active) and scan the entire environment for **chroma.exe** and **mimikatz.exe**.
- **Short-Term Hardening (1–7 days)**
  1. Brute-Force Prevention
     - Enable account lockout policies (e.g., lock after 5 failed attempts for 15 minutes).
     - Enforce strong password policies and enable MFA wherever possible.
     - Create Splunk/SIEM alert: > 50 failed logons (Event ID 4625) from the same source in 5 minutes.
  2. Defense Evasion Controls
     - Enable PowerShell Script Block Logging (Event ID 4104) and Module Logging across all endpoints.
     - Create detection rule for Add-MpPreference, -ExclusionPath, -NonInteractive, and similar parameters.

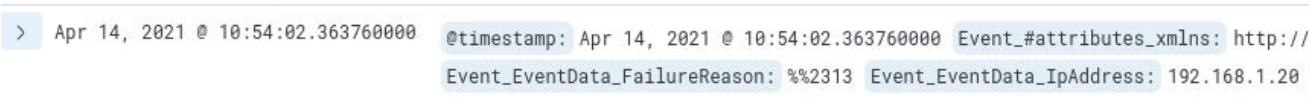
    - Monitor Windows Event ID 5007 (Defender configuration changes).
  3. Endpoint Protection
    - Ensure Windows Defender Real-Time Protection is enabled and cannot be disabled via policy.
    - Deploy or tune EDR (e.g., Microsoft Defender for Endpoint) to block known Mimikatz signatures and LSASS access.
    - Quarantine and remove **chroma.exe** and the mimi folder.
  4. Ransomware-Specific Mitigations
    - Block the observed killswitch domain at DNS level.
    - Patch all systems against MS17-010 (EternalBlue) and other SMB vulnerabilities.
    - Implement network segmentation to limit lateral movement from compromised accounts.
- **Long-Term Improvements**
  - Conduct regular red-team exercises simulating this exact attack chain.
  - Implement least-privilege access and just-in-time admin rights.
  - Schedule automated vulnerability scanning and patch management.
  - Enhance SOC playbooks with automated response for brute-force + AV-bypass patterns.

4.Investigation screenshots



Filter failed with EventId 4625 (An account failed to log on).





Hunt 1 (2/3) - What is the observed logon type? (Format: Logon Type Name) *(6 points)*

network | Correct! ✔

```
> Apr 14, 2021 @ 10:54:02.363760000   @timestamp: Apr 14, 2021 @ 10:54:02.363760000  Event_#attributes_xmlns:
  Event_EventData_FailureReason: %%2313  Event_EventData_IpAddress: 192.1
  Event_EventData_LogonProcessName: NtLmSsp  Event_EventData_LogonType: 3
```

logon type is 3.

AI Mode | All | Images | Videos | Forums | Shopping | Short videos | More | Tools

ManageEngine
https://www.manageengine.com › products › what-is › l...

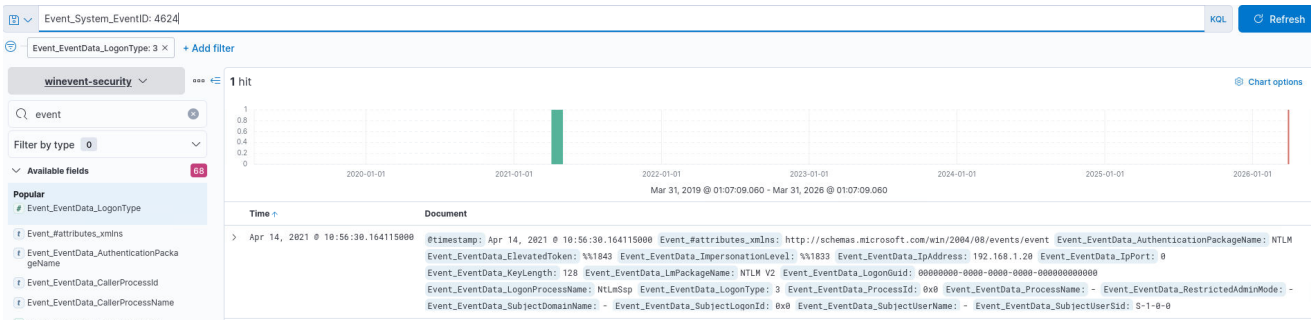
Windows logon type 3

Logon type 3 denotes a network logon. A network logon or any other logon can take place only after an interactive logon authentication has taken place. Read more

Hunt 1 (3/3) - What is the time of the first successful logon after the brute force? (Format: Format:DD-MM-YYYY hh:mm:ss) *(6 points)*

14-04-2021 10: 56: 30 | Correct! ✔

there are 1804 failed log on attemps. And all of them are from network log on. So keep logon type 3 and filter EventID 4624(An account was successfully logged on)




```
H2 - Windows Defender Bypass
Source: sysmon/winevent-powershell
```

Hunt 2 (1/2) - What is the full command used for bypassing the defender scan on the malicious file? (Format: powershell.exe ... Full Command (Do not include the file path)) *(6 points)*

powershell.exe -inputformat none -outputformat none -NonInteractive -Command Add-MpPreference -ExclusionPath

For detect the command for bypassing the defender scan on the malicious file, I do research and get answers as follow:

- 1. Monitor for Defender Configuration Changes

  Attackers often bypass scans by adding the malicious file or its folder to the **Exclusion List**. You can detect the commands used for this by looking for specific PowerShell activity:

  - **Search for Cmdlets**: Look for `Add-MpPreference` or `Set-MpPreference` with the `-ExclusionPath`, `-ExclusionExtension`, or `-ExclusionProcess` parameters.
  - **Check Windows Event Log**:

        - **Event ID 5007**: Configuration has changed. This log will show if an exclusion was added or a feature like Real-Time Protection was disabled.
        - **Event ID 1116 & 1117**: These show when a threat is detected and what action was taken. If a bypass was successful, you might see a "detected" event followed by no remediation if the user or a script intervened.
    - **PowerShell Script Block Logging (Event ID 4104)**: This is critical for capturing the **full text** of a command, even if it was obfuscated or base64 encoded.
- 3. Review Defender Operational Logs

For deeper forensics on how Defender handled a specific file, check the dedicated operational logs:

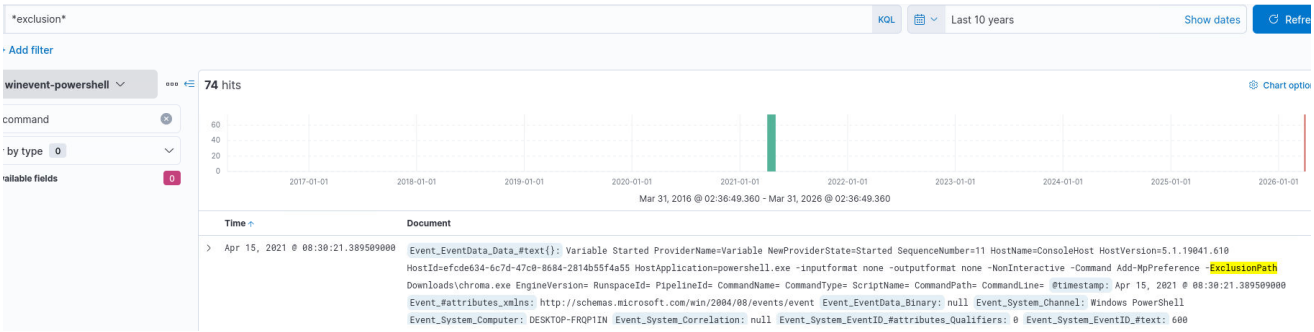
    - **Path**: `Applications and Services Logs > Microsoft > Windows > Windows Defender > Operational` .
    - **Offline Scan Logs**: If the bypass involved the offline scanner, logs are stored in `C:\Windows\Microsoft Antimalware\Support` with the naming convention `MPLog-<date>-<time>.log` .
- 4. Detection via Command Line Tools

You can query the current state of Defender to see if any suspicious bypasses (like exclusions) are currently active:

    - **PowerShell**: Run `Get-MpPreference` to see all current exclusions and protection settings.
    - **MpCmdRun.exe**: Use the Defender command-line tool located in `%ProgramFiles%\Windows Defender` to run a custom scan and check for skipped paths, which may indicate a hidden exclusion

Hunt 2 (2/2) - What is the filename of the malicious application? (Format: filename.extension)

chroma.exe

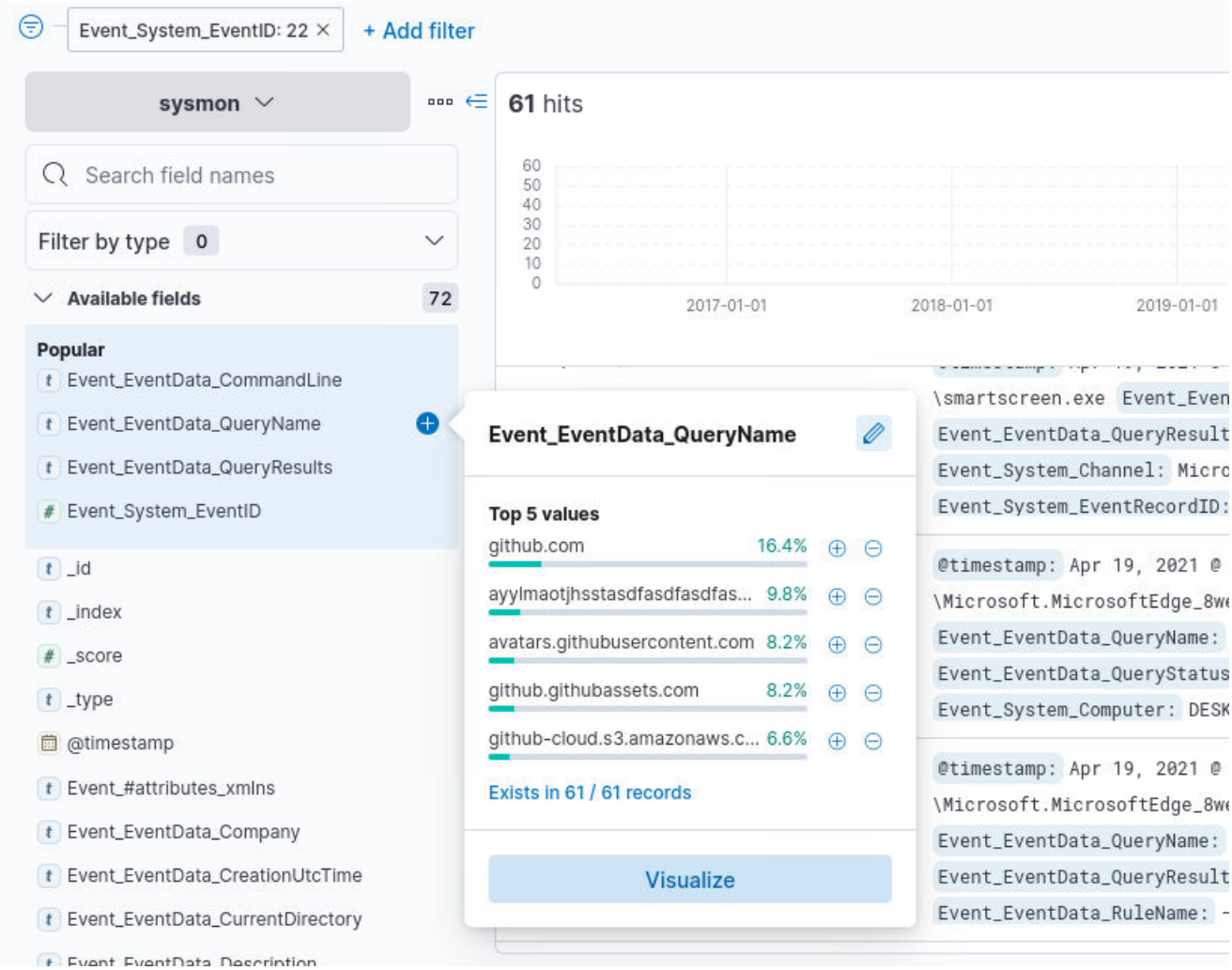


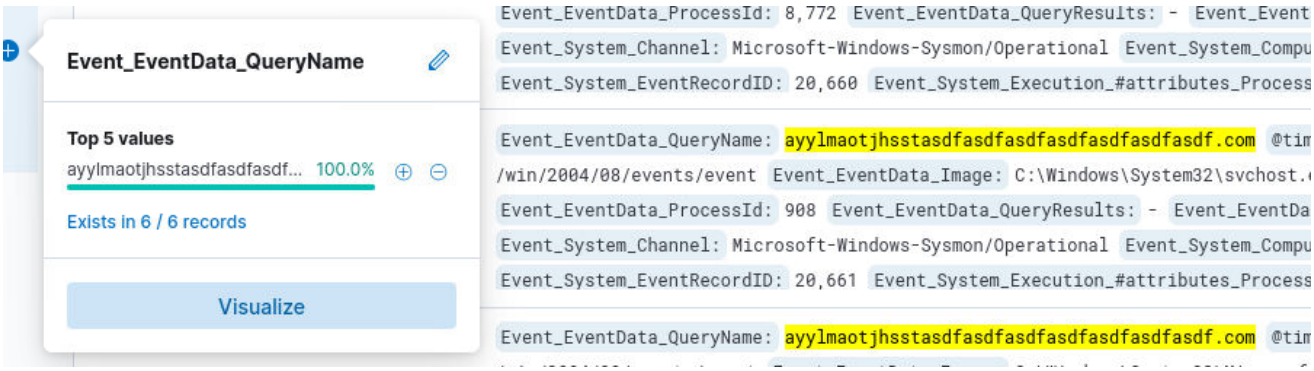
H3 - WannaCry KillSwitch Domain
Source: sysmon

Hunt 3 (1/2) - What is the domain name? (Format: domain.tld) *(6 points)*

ayylmaotjhsstasdfasdfasdfasdfasdfasdfas

Correct!





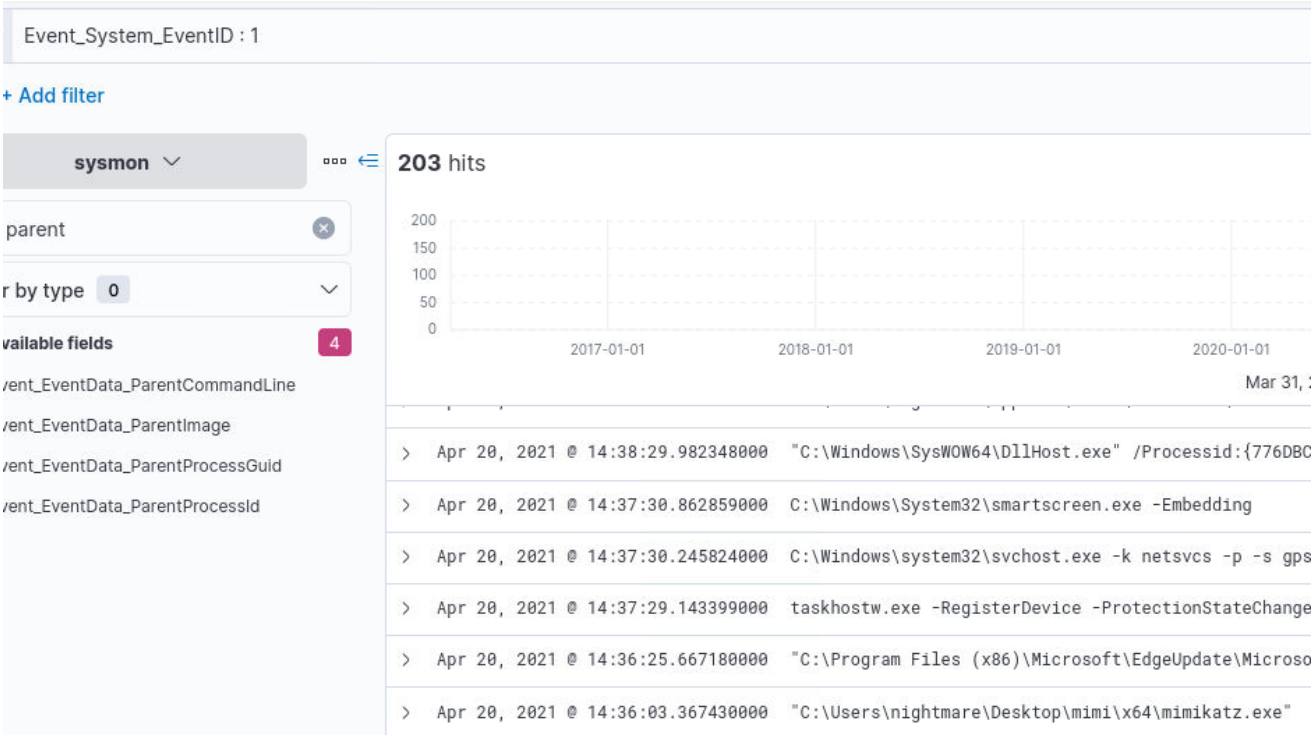
Hunt 3 (2/2) - What is the Execution ProcessID and ThreadID? (Format: pid, tid) *(7 points)*

2724, 4260 Correct! ✔

By clicking one item from the list, we will find more details about the log. we can get the PID and TID.

# Event_System_Execution_#attributes_ProcessID	2,724
# Event_System_Execution_#attributes_ThreadID	4,260

Hunt 4 (1/1) - What is the full path of the exe used for dumping password? (Format: C:\path\to\file.extension) *(7 points)*

C:\Users\nightmare\Desktop\mimi\x64\mim Correct!

filter the log with EventId:1 Or 10. We get 203 items. then we know the duming password shoud be after the event of log successfully at 10:56:30 on 14-04-2021. And we know it may be at the middle or end part of the investigation because it is the stage of actions on objectives.